TP_Cybersécurité

RAPPORT D'AUDIT DE SÉCURITÉ

Contexte du projet

Ce mini projet a pour objectif de réaliser un audit de sécurité basique en scannant les ports d'une machine virtuelle volontairement vulnérable (Metasploitable). L'exercice est réalisé dans un environnement de lab isolé, sans impact sur un réseau de production.

1.1 Type de test

Test réalisé : scan de reconnaissance (passif/actif) avec Nmap.

- Scan de ports TCP/UDP
- Détection des services et de leurs versions
- Identification des protocoles actifs

1.2 Périmètre du projet

L'environnement est entièrement virtualisé via VirtualBox. Au départ, les deux machines n'étaient pas sur le même réseau. La configuration a été ajustée en mode Host-Only pour permettre la communication entre elles.

Élément	Détail
Machine attaquante	Kali Linux
Machine cible	Metasploitable
Outil de virtualisation	VirtualBox
Configuration réseau	Host-Only (adresses IP sur le même sous-réseau)
Logiciel	Nmap

2. Surface d'attaque

Le scan Nmap réalisé depuis la machine Kali Linux a permis d'identifier un grand nombre de ports ouverts sur la machine Metasploitable. Ces ports exposent plusieurs services réseau accessibles sans restriction.

Principaux ports et services détectés :

Port	Service	Version détectée	État
22	SSH	OpenSSH 9.2p1	Ouvert
21	FTP	vsftpd 2.3.4	Ouvert
25	SMTP		Ouvert
443	HTTPS		Ouvert

Le nombre élevé de ports ouverts élargit considérablement la surface d'attaque. Chaque service actif représente un vecteur d'entrée potentiel pour un attaquant.

3. Principales vulnérabilités identifiées

L'analyse des versions des services détectés a permis de retrouver des vulnérabilités connues et référencées dans la base CVE.

Service	Version	CVE	Gravité	Description
SSH	OpenSSH 9.2p1	CVE-2023-38408	Critique	Exécution de code à distance via un agent SSH malveillant
FTP	vsftpd 2.3.4	CVE-2011-2523	Critique	Backdoor intégrée permettant un accès root non autorisé
Accès root direct			Critique	Accès obtenu via nc <ip> sans authentification

Point notable : lors du test, il a été possible d'obtenir un accès root complet à la machine Metasploitable en utilisant simplement la commande nc <ip> depuis Kali Linux, sans aucune authentification. Cela signifie qu'un port en écoute acceptait des connexions non sécurisées avec des droits administrateur.

4. Niveau de risque global

Niveau de risque global : CRITIQUE

Ce niveau de risque s'explique par plusieurs facteurs combinés :

- De nombreux ports sont ouverts sans justification apparente, augmentant la surface d'attaque.
- Des services tournent avec des versions obsolètes présentant des failles documentées et exploitables.
- Certains services (FTP, SMTP) transmettent des données en clair, ce qui expose les communications à des interceptions.

5. Recommandations prioritaires

Sur la base des vulnérabilités observées, plusieurs actions sont à mettre en place pour sécuriser la machine.

La première priorité est de mettre à jour le système. Tous les packages doivent être mis à jour régulièrement. Le service vsftpd 2.3.4, qui présente une backdoor connue, doit être remplacé par une version récente ou désactivé s'il n'est pas utilisé. De manière générale, aucun service ne devrait tourner avec une version obsolète ayant des failles documentées.

Ensuite, il est important de réduire la surface d'attaque en fermant tous les ports qui ne sont pas strictement nécessaires. Chaque port ouvert est une porte d'entrée potentielle.

Le renforcement des accès est également critique. L'accès root obtenu via la commande nc sans aucune authentification est inacceptable dans un environnement réel. Il faut désactiver tout service permettant ce type de connexion non sécurisée. Pour SSH, la connexion directe en tant que root doit être interdite, et l'authentification par clé doit être préférée à l'authentification par mot de passe.

Enfin, les communications doivent être chiffrées. Les protocoles qui transmettent les données en clair, comme FTP ou SMTP non sécurisé, doivent être remplacés par leurs équivalents chiffrés (SFTP, SMTPS). HTTPS doit être correctement configuré avec un certificat valide et des versions récentes du protocole TLS.